

SOC GÖSTERGELERİ VE HEDEFLERİ

[Kaynak](#)

İÇERİK

1. Temel SOC Metrikleri (Core Metrics)
2. Triage (Önceliklendirme) ve Zaman Temelli SOC Metrikleri
3. SOC Performans Metriklerini İyileştirme (Improving Metrics)

Temel SOC Metrikleri (Core Metrics)

Bir **SOC** (Security Operations Center) biriminin temel varoluş amacı, organizasyonun dijital varlıklarının Gizlilik (Confidentiality), Bütünlük (Integrity) ve Erişilebilirlik (Availability) üçgenini mutlak surette korumaktır. SOC ekipleri bu koruma kalkanını, güvenlik sensörlerinden gelen uyarıları (alerts) alarak, kendi algılama kurallarını geliştirerek ve en önemlisi **Triage** (Gelen alarmları analiz ederek ciddiyetine ve doğruluğuna göre önceliklendirme/sınıflandırma) işlemi yaparak sağlar.

Bu ekosistemde Seviye 1 (**L1**) analistlerinin varoluşsal görevi, gürültüyü filtrelemek ve **True Positive** (Gerçek Pozitif - Gerçek bir siber saldırı veya güvenlik ihlali) olarak doğrulanan olayları güvenilir bir süzgeçten geçirerek daha derinlemesine analiz için Seviye 2 (**L2**) analistlere aktarmaktır. SOC ekibinin bu işleymdeki verimliliğini, teknik kapasitesini ve kör noktalarını tespit etmek için dört kritik performans metriği kullanılır.

SOC Performansını Ölçen Temel Formüller

Aşağıdaki metrikler, SOC'un salt yoğunluğunu değil, aynı zamanda log kaynaklarının sağlığını ve analistlerin tecrübe seviyesini de matematiksel olarak ortaya koyar.

$AC \text{ (Alerts Count)} = \text{Gelen Toplam Uyarı Sayısı}$

Mantık: SOC analistlerinin genel iş yükünü ve görünürlüğün (visibility) hacmini ölçer.

$FPR \text{ (False Positive Rate)} = \text{Hatalı Pozitif Sayısı} / \text{Toplam Uyarı Sayısı}$

Mantık: Sistemdeki gürültü oranını ölçer. Yanlış yapılandırılmış veya aşırı hassas kuralların tespitinde kullanılır.

$AER \text{ (Alert Escalation Rate)} = \text{Üst Seviyeye Aktarılan Uyarı Sayısı} / \text{Toplam Uyarı Sayısı}$

Mantık: L1 analistlerinin tecrübesini, inisiyatif alma ve filtreleme kabiliyetlerini ölçer.

$TDR \text{ (Threat Detection Rate)} = \text{Tespit Edilen Tehditler} / \text{Toplam Gerçekleşen Tehditler}$

Mantık: SOC ekibinin ve kullanılan güvenlik teknolojilerinin nihai güvenilirliğini ve başarısını ölçer.

Uyarı Sayısı (Alerts Count - AC)

Bir L1 analisti olarak mesaiye başladığınızda kuyrukta bekleyen 80 adet çözülmemiş alarm görmek, analitik odağı dağıtan ve analistleri yoran bir durumdur. Bu kadar yüksek hacimli bir uyarı kuyruğunda, gerçek hedeflenmiş saldırıların (örneğin bir **APT** - Advanced Persistent Threat aktivitesinin) sıradan sistem gürültüleri arasına saklanarak gözden kaçma ihtimali çok yüksektir.

Ancak madalyonun diğer yüzü çok daha tehlikelidir. Koca bir hafta boyunca **hiçbir** alarm almadığınızı düşünün. Bu, ortamın %100 güvenli olduğu anlamına gelmez. Siber güvenlikte mutlak sessizlik, genellikle bir şeylerin kırıldığının işaretidir. Düşük veya sıfır alarm durumu; **SIEM** (Security Information and Event Management) mimarisindeki bir log ayrıştırma (parsing) hatasına, ajanların (agent) log göndermeyi kesmesine veya ağda kritik bir görünürlük (visibility) kaybına işaret eder. Böyle bir durumda sistem ihlal ediliyor olabilir ve SOC'un bundan haberi dahi yoktur.



ÖNEMLİ: Kurumun ölçeğine ve log kaynaklarının hacmine göre değişmekle birlikte, endüstri standardı olarak bir L1 analistinin vardiya başına günlük ortalama **5 ila 30** arasında alarm incelemesi ideal kabul edilir. Bu sayı, analistin her bir alarma gereken analitik derinliği ayırabilmesine olanak tanır.

Hatalı Pozitif Oranı (False Positive Rate - FPR)

Eğer incelediğiniz 80 alarmın 75'i (%94 oranında) standart BT operasyonları (örneğin bir sistem yöneticisinin yasal bir PowerShell scripti çalıştırması) veya zararsız ağ gürültüsü çıkıyorsa, tespit mimarinizde ciddi bir sorun var demektir.

Yüksek FPR, siber güvenlik psikolojisindeki en tehlikeli durumlardan biri olan **Alert Fatigue** (Alarm Yorgunluğu) sendromunu tetikler. Analistler sürekli olarak "bu da standart bir gürültüdür" önyargısıyla hareket etmeye başlar, dikkatleri dağınık ve gerçekten zararlı olan **Payload** (Saldırganın sistemde çalıştırdığı asıl zararlı kod parçası) gözden kaçır.

DİKKAT: %0 oranında bir False Positive elde etmek teknik olarak imkansızdır (ve istenmez, çünkü bu durum kuralların çok gevşek yazıldığını ve True Positive'leri de kaçırdığınızı gösterir). Ancak **%80 ve üzeri** bir FPR, kırmızı alarmdır. Bu durum, tespit mühendisleri (Detection Engineers) tarafından SIEM kurallarının sıkılaştırılması, istisnaların (whitelisting) tanımlanması ve **"False Positive Remediation"** (Hatalı Pozitif İyileştirmesi) sürecinin derhal başlatılması ile çözümlenmelidir.

Alarm Yükseltme Oranı (Alert Escalation Rate - AER)

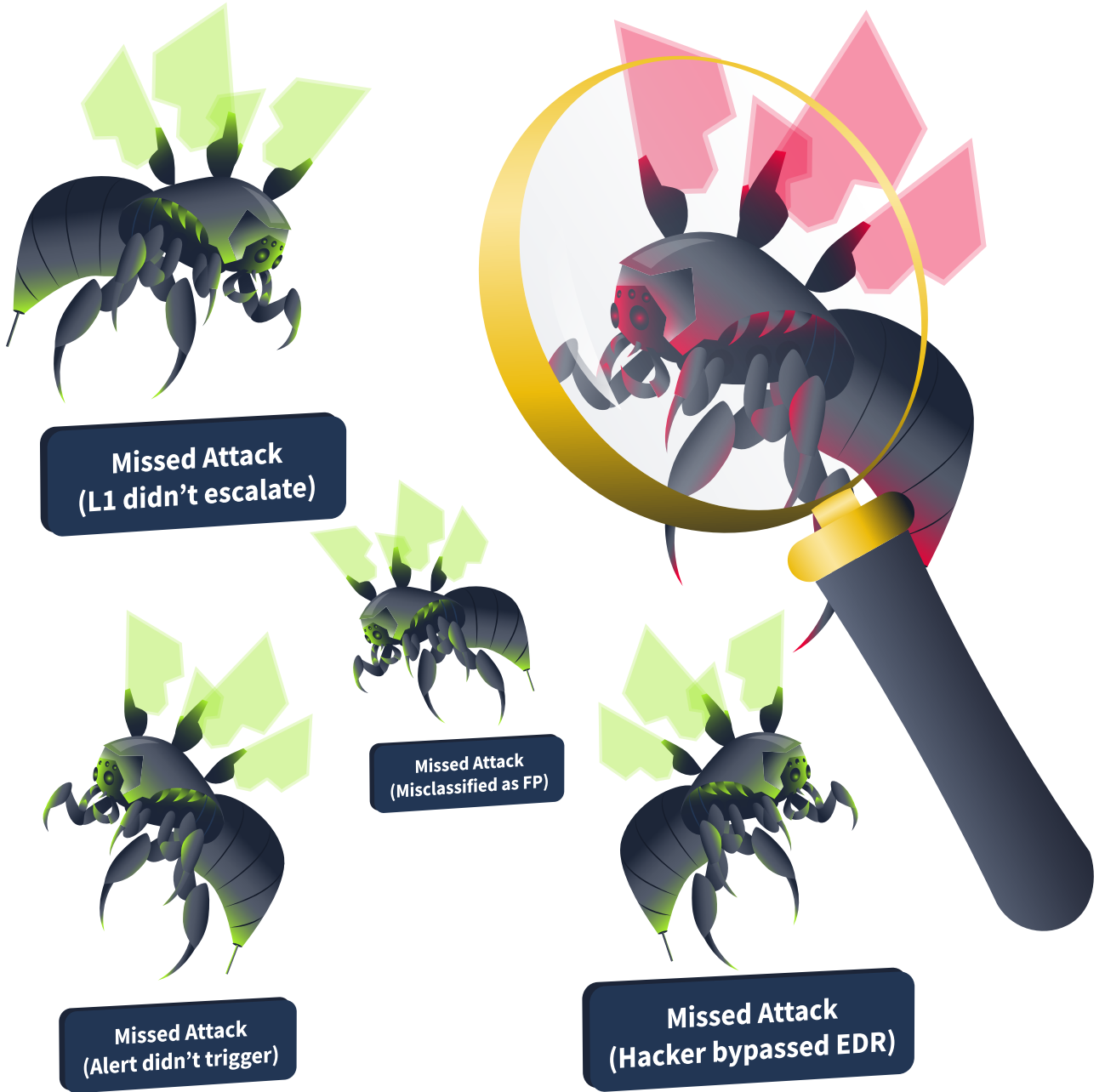
SOC hiyerarşisinde L2 analistler, L1 analistlerinin gürültüyü başarılı bir şekilde süzdüğüne ve sadece gerçekten tehdit barındıran, eyleme geçirilebilir (actionable) alarmları kendilerine **Escalate** (Yükseltme/Aktarma) edeceğine güvenir.

Bir L1 analistinin karşılaştığı en büyük zorluk dengeyi kurmaktır: Teknik detayına tam hakim olmadığınız, şüpheli bir belleğe enjeksiyon (Memory Injection) veya karmaşık bir komut ve kontrol (**C2**) trafiğini, kıdemli bir analistten destek almadan tek başınıza kapatacak kadar özgüvenli olmamalısınız. Ancak aynı zamanda, basit bir port tarama (Port Scanning) olayını bile doğrudan L2'ye aktararak onların iş yükünü artırmamalısınız.

AER metriği, L1 ekibinin olaylara ne kadar hakim olduğunu ve bağımsız karar verebilme yetkinliğini ölçer. Sektörel olarak L1 analistlerinin gelen alarmların **%50'sinden azını**, ideal bir olgunluk seviyesinde ise **%20'sinden azını** bir üst seviyeye yükseltmesi hedeflenir.

Tehdit Tespit Oranı (Threat Detection Rate - TDR)

TDR, bir SOC'un varlık sebebinin nihai sınavıdır. Örneğin, 2025 yılı içerisinde organizasyonunuza yönelik 6 adet ciddi siber saldırı gerçekleştiğini varsayalım. Ekibiniz 4 saldırıyı tespit edip engelledi. Ancak 5. saldırıyı hatalı yazılmış bir tespit kuralı (**Broken Detection Rule**) yüzünden göremediniz, 6. saldırıyı ise bir L1 analistinin dikkatsizliği sonucu olayı False Positive olarak kapatması nedeniyle kaçırdınız.



Bu senaryoda $TDR = 4 / 6 = \%67$ olarak hesaplanır. Siber güvenlik alanında bu kabul edilemez, felaket düzeyinde bir başarısızlıktır. Eğitim veya sertifikasyon sınavlarında %67 geçer bir not olabilir, ancak gerçek dünyada TDR metriği **her zaman %100'ü hedeflemek zorundadır**.

Kaçırılan tek bir tehdidin (%1'lik bir yanılma payının bile) arka plandaki teknik faturası; tüm şirketin **Ransomware** (Fidye Yazılımı) ile şifrelenmesi veya kritik müşteri verilerinin dışarı sızdırılması (**Data Exfiltration**) olacaktır. SOC operasyonlarında "çoğunu yakaladık" şeklinde bir başarı kriteri yoktur; kaçırılan tek bir saldırı tüm savunma hattının çökmesi anlamına gelir.

Triage (Önceliklendirme) ve Zaman Temelli SOC Metrikleri

Siber güvenlik operasyonlarında temel bir kural vardır: Sadece bir alarmin (alert) üretilmiş olması, devam eden bir ihlali veya saldırıyı durdurmaz. Bir tehdidin başarıya ulaşmasını

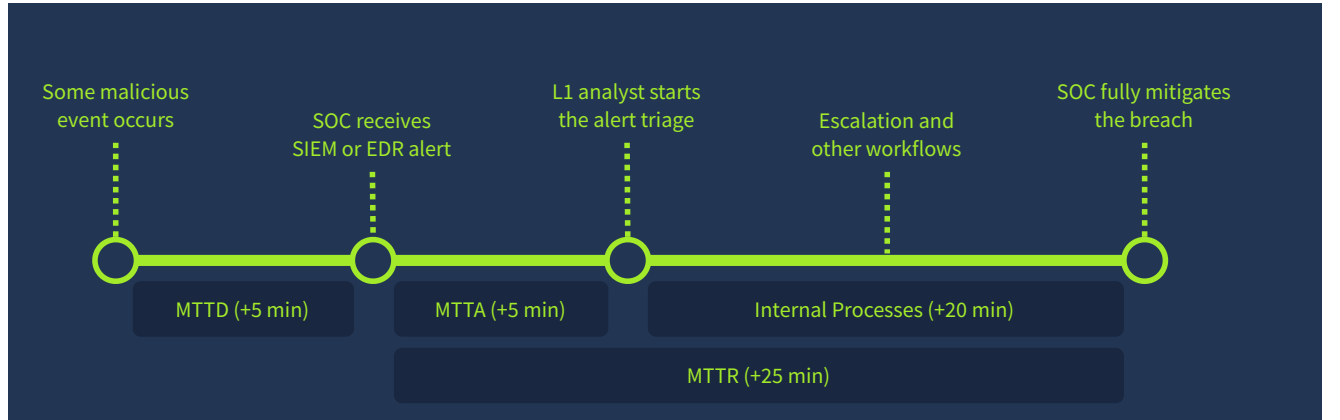
engellemek için alarmin zamanında alınması, doğru bir şekilde **Triage** (Gelen alarmların ciddiyetine, sistem üzerindeki etkisine ve doğruluğuna göre analiz edilip önceliklendirilmesi süreci) edilmesi ve saldırgan hedefine ulaşmadan önce olaya müdahale edilmesi kritik bir zorunluluktur.

Bu hızlı tespit ve iyileştirme (remediation) sürecini standartlaştırmak ve ölçülebilir kılmak için **SLA (Service Level Agreement - Hizmet Seviyesi Sözleşmesi)** adı verilen yapısal bir doküman kullanılır. SLA, kurum içi **SOC (Security Operations Center)** ekibi ile şirket yönetimi arasında veya dışarıdan hizmet veren bir **MSSP (Managed Security Service Provider)** ile müşterileri arasında imzalanan, bağlayıcı performans metriklerini içeren anlaşmadır.

ÖNEMLİ: SLA, bir SOC ekibinin lüksü değil, varoluşsal performans göstergesidir. Başarılı bir SLA yönetimi; tehdidin ne kadar sürede tespit edildiğini, L1 (Seviye 1) analistlerinin bu tehdidi ne kadar sürede incelemeye aldığını ve nihai olarak tehdidin yayılmasının ne kadar sürede durdurulduğunu matematiksel olarak ortaya koyar.

Saldırı Yaşam Döngüsü ve Zaman Metriklerinin Mantıksal Akışı

Bir siber saldırı anında geçen her saniye, saldırganın yanal hareket (Lateral Movement) yapması veya veri sızdırması (Data Exfiltration) için bir fırsattır. SLA kapsamında takip edilen zaman metrikleri, aslında birbirini tetikleyen bir zincirin halkalarıdır.



Aşağıdaki şema, metriklerin olay anındaki kronolojik sıralamasını ve teknik bağlamını göstermektedir:

[Saldırı Başlangıcı (Zero Hour)]

|

|---> Zaman İşliyor: SOC araçlarının olayı fark etmesi bekleniyor.

v

[Alarm Üretimi] ---> Bu aşamaya kadar geçen süre: MTTD (Tespit Süresi)

|

|---> Zaman İşliyor: Alarm kuyrukta bekliyor. L1 analistinin olayı üstlenmesi bekleniyor.

v

[İnceleme (Triage) Başlangıcı] ---> Bu aşamaya kadar geçen süre: MTTA (Kabul/Üstlenme Süresi)

|
|---> Zaman İşliyor: Analiz yapılıyor, L2'ye aktarılıyor (Escalation)
veya cihaz izole ediliyor.
v
[Tehdidin Durdurulması/İzolasyon] ---> Tüm bu sürecin başından sonuna kadar geçen süre: MTTR (Müdahale Süresi)

DİKKAT: Farklı güvenlik ekipleri, kendi organizasyonel hedeflerine göre bu metrikler için farklı başlangıç ve bitiş noktaları (formüller) tanımlayabilir. Ancak endüstri standardı olarak kabul edilen tanımlar ve hedef süreler aşağıda detaylandırılmıştır.

Temel Triage Metrikleri ve Teknik Analizleri

SOC süreçlerinin sağlığını ölçmek için kullanılan standart referans tablosu ve bu değerlerin arka plandaki teknik anlamları şunlardır:

Metrik	Sektör Standartı SLA Hedefi	Tanım ve Teknik Derinlik
SOC Team Availability (SOC Ekibi Erişilebilirliği)	24/7 (Kesintisiz)	Açıklama: SOC ekibinin çalışma takvimidir. Geleneksel 8/5 (Pazartesi-Cuma, mesai saatleri) çalışma modeli, siber güvenlikte büyük bir zafiyettir çünkü APT (Gelişmiş Sürekli Tehdit) grupları ve fidye yazılımı (Ransomware) operatörleri genellikle hedef kurumun mesai saatleri dışını, hafta sonlarını veya resmi tatilleri hedef alır. 24/7 erişilebilirlik , olaylara anında müdahale için şarttır.
MTTD (Mean Time to Detect - Ortalama Tespit Süresi)	5 Dakika	Açıklama: Gerçekleşen bir saldırı ile bu saldırının SOC araçları (SIEM, EDR, IDS vb.) tarafından algılanıp alarm üretilmesi arasında geçen ortalama süredir. Teknik Yorum: Bu metrik tamamen kullandığınız güvenlik sensörlerinin kalitesine ve yazdığınız tespit kurallarının (Detection Rules) verimliliğine dayanır. Eğer MTTD süreniz yüksekse, logların SIEM'e ulaşmasında gecikmeler (ingestion lag) var demektir veya saldırgan, kurallarınızı atlatacak gizlilik teknikleri (Evasion) kullanıyordur.
MTTA (Mean Time to Acknowledge - Ortalama Kabul Süresi)	10 Dakika	Açıklama: Üretilen ve kuyruğa düşen yeni bir alarmın, bir L1 analisti tarafından görülüp Triage işlemine (durumun incelenmeye başlanması) başlanması için geçen ortalama süredir. Teknik Yorum: Bu metrik insan faktörünü ölçer.

Metrik	Sektör Standartı SLA Hedefi	Tanım ve Teknik Derinlik
		MTTA süresi uzuyorsa, L1 analistlerinizin üzerinde aşırı bir iş yükü (Alert Fatigue - Alarm Yorgunluğu) vardır veya SIEM ekranında çok fazla "False Positive" (Hatalı Pozitif) gürültüsü olduğu için gerçek alarmlar gözden kaçıyor.
MTTR (Mean Time to Respond - Ortalama Müdahale Süresi)	60 Dakika	Açıklama: SOC ekibinin saldırıyı fark edip, ihlalin ağ içinde yayılmasını (örneğin zararlı yazılımın diğer makinelere sıçramasını) fiilen durdurması için geçen ortalama süredir. Teknik Yorum: En hayati metriktir. "Müdahale" kavramı, sadece alarmı kapatmak değil; ele geçirilmiş bir hesabı kilitlemek (Account Disable), zararlı iletişim kuran IP adresini güvenlik duvarında engellemek (Block/Drop) veya enfekte olmuş sunucuyu ağdan izole etmek (Host Isolation) gibi somut aksiyonları içerir. MTTR'ın yüksek olması, Playbook (Müdahale adımlarını içeren rehberler) eksikliğine veya ekipler arası (SOC ile Ağ Yöneticileri arası) iletişim kopukluğuna işaret eder.

SOC Performans Metriklerini İyileştirme (Improving Metrics)

Bir Seviye 1 (L1) analisti olarak sadece alarmlara bakmak ve kapatmak yeterli değildir; arka planda işleyen analitik yapıyı ve performans metriklerini anlamak, sıradan bir operatör ile gerçek bir siber güvenlik uzmanı arasındaki temel farkı yaratır. Metrikler, SOC'un (Security Operations Center) genel sağlığının ve savunma mimarisinin ne kadar verimli çalıştığının matematiksel bir yansımasıdır.



Bu metriklerin optimizasyonu sadece organizasyonun dijital varlıklarını korumakla kalmaz, aynı zamanda analistin kişisel performans değerlendirmesinde (**KPI**) de doğrudan rol oynar. Alarmları başarılı bir şekilde filtreleyebilen, gürültüyü azaltan ve olayları hızlıca doğru yöne kanalize eden bir L1 analisti, teknik olgunluğunu kanıtlayarak **L2** (Seviye 2 - Olay Müdahale ve Derinlemesine Analiz) rollerine hızla terfi eder.

Aşağıda, bir SOC ortamında karşılaşılan kritik darboğazlar (bottlenecks) ve bu metrikleri sektör standartlarına çekmek için uygulanması gereken ileri düzey teknik stratejiler detaylandırılmıştır.

Yüksek Hatalı Pozitif Oranı (False Positive Rate > %80) ve İyileştirme Stratejisi

Problem Tanımı: Ekrana düşen alarmların %80'inden fazlası gerçek bir tehdit barındırmıyor ve zararsız sistem hareketlerinden oluşuyorsa, SOC ekibi **Alert Fatigue** (Alarm Yorgunluğu) adı verilen psikolojik ve operasyonel bir çöküş yaşar. Gerçek bir hedeflenmiş saldırı (**APT** - Advanced Persistent Threat), bu devasa gürültü yığınının arasında kolayca gizlenebilir.

Teknik Çözüm ve Mantık Zinciri: Bu sorunu çözmek için proaktif bir **Rule Tuning** (Kural İyileştirme ve Optimizasyon) süreci başlatılmalıdır.

- 1. Güvenilir Aktivitelerin İstisna Edilmesi (Whitelisting):** EDR (Endpoint Detection and Response) ajanlarından veya **SIEM** (Security Information and Event Management) sisteminden gelen standart işletim sistemi güncellemeleri, yasal zafiyet tarama araçlarının (Vulnerability Scanners) oluşturduğu trafik veya yetkili sistem yöneticilerinin onaylı işlemleri tespit kurallarından (Detection Rules) dışlanmalıdır. Bu işlem, belirli dosya hash'leri, IP blokları veya onaylı proses ağaçları (Process Trees) baz alınarak yapılır.

2. **SOAR ile Otomasyon:** Sürekli tekrar eden ve bilinen "False Positive" kalıpları için **SOAR** (Security Orchestration, Automation, and Response) platformları devreye sokulmalıdır. Özel Python scriptleri veya SOAR playbook'ları kullanılarak, alarmın L1 analistinin önüne düşmeden önce otomatik olarak sorgulanması (örneğin; "bu IP adresi VirusTotal'de temiz mi ve kurum içi whitelist'te var mı?") ve zararsız ise otomatik olarak kapatılması sağlanır.

ÖNEMLİ: SOAR veya otomasyon betikleri yazılırken, kuralların çok geniş yazılmamasına dikkat edilmelidir. Aksi takdirde True Positive (Gerçek Tehdit) olan bir alarm da otomatik olarak kapatılabilir (**False Negative** zafiyeti).

Gecikmeli Tespit: Yüksek MTTD (Mean Time to Detect > 30 Dakika)

Problem Tanımı: Gerçekleşen bir saldırının SOC araçları tarafından tespit edilmesi 30 dakikadan uzun sürüyorsa, saldırgan çoktan yanal hareket (**Lateral Movement**) yapmış veya kritik sistemlerde kalıcılık (**Persistence**) sağlamış olabilir. Tespit süresi ne kadar uzunsa, hasarın boyutu da eksponansiyel olarak artar.

Teknik Çözüm ve Mantık Zinciri:

1. **Tespit Kurallarının (Detection Rules) Optimizasyonu:** Kurallar çok karmaşık yazılmış (örneğin aşırı yük getiren RegEx sorguları) veya çok geniş bir zaman aralığını tarıyor olabilir. L1 analisti, bu gecikmeyi fark ettiğinde durumu doğrudan SOC Mühendislerine (Detection Engineers) raporlamalıdır. Kurallar, işlemciyi yormadan daha sık ve hızlı çalışacak şekilde optimize edilmelidir.
2. **Log Ingestion Lag (Logların Gecikmeli Gelmesi) Kontrolü:** Tespitin yavaş olmasının asıl nedeni kurallar değil, verinin kendisi olabilir. Hedef sistemlerden SIEM'e logların gerçek zamanlı (Real-Time) akıp akmadığı kontrol edilmelidir. Ağdaki bant genişliği sorunları veya yanlış yapılandırılmış ajanlar (agents) nedeniyle loglar SIEM'e 10-15 dakika gecikmeli ulaşıyorsa, MTTD süresini düşürmek matematiksel olarak imkansızdır.

Triage Gecikmesi: Yüksek MTTA (Mean Time to Acknowledge > 30 Dakika)

Problem Tanımı: Alarm SIEM'de başarıyla üretilmiş, ancak bir L1 analistinin bunu fark edip **Triage** (İnceleme ve önceliklendirme) sürecine başlaması yarım saatten fazla sürmektedir. Bu durum tamamen insan kaynağı ve süreç yönetimi ile ilgili bir zafiyettir.

Teknik Çözüm ve Mantık Zinciri:

1. **Gerçek Zamanlı Bildirim (Alerting Mechanisms):** Analistler sadece SIEM ekranına bakarak olayları takip edemez. Kritik veya yüksek (High/Critical) seviyeli alarmlar için anlık bildirim sistemleri kurulmalıdır. (Örn: Slack/Teams Webhook entegrasyonları, PagerDuty bildirimleri). Yeni bir alarm düştüğünde analistin anında haberdar olması şarttır.

2. **İş Yüğü Dağıtımı (Load Balancing):** Vardiyada çalışan L1 analistleri arasında adaletsiz bir alarm dağılımı varsa (bir analist 50 alarm incelerken diğeri 5 alarm inceliyorsa), MTTA süresi kaçınılmaz olarak uzar. Kuyruktaki (Queue) alarmların vardiya personeline eşit ve otomatik olarak dağıtılması (Round-robin veya yetkinlik bazlı atama) sağlanmalıdır.

Başarısız Müdahale: Yüksek MTTR (Mean Time to Respond > 4 Saat)

Problem Tanımı: SOC ekibi tehdidi görmüş, incelemiş ancak ihlali (breach) zamanında durduramamıştır. 4 saatin üzerindeki bir tepki süresi, bir fidye yazılımının (**Ransomware**) tüm ağı şifrelemesi veya gigabaytlarca verinin dışarı sızdırılması (**Data Exfiltration**) için fazlasıyla yeterli bir süredir.

Teknik Çözüm ve Mantık Zinciri:

1. **Hızlı ve İsabetli Escalation (Üst Seviyeye Aktarma):** L1 analistinin görevi zafiyeti tek başına çözmek değil, durumu analiz edip gerçek bir tehlike tespit ettiğinde **zaman kaybetmeden** L2 ekibine aktarmaktır (Escalate). L1 analisti; saldırganın IP adresi, etkilenen host bilgisi, çalıştırılan zararlı komut (Payload) gibi **IOC**'leri (Indicators of Compromise - Uzlaşma Göstergeleri) hızlıca derleyip paketi L2'ye sunmalıdır. Kararsızlık, süreci uzatan en büyük düşmandır.
2. **Playbook (Müdahale Senaryoları) Kullanımı:** Kriz anında kimsenin "şimdi ne yapmalıyız?" diye düşünme lüksü yoktur. Phishing (Oltalama), Malware Enfeksiyonu veya Brute-Force (Kaba Kuvvet) saldırıları gibi farklı senaryolar için standart operasyon prosedürleri (**SOP** - Standard Operating Procedures) ve **Playbook**'lar önceden yazılmış, test edilmiş ve tüm ekip tarafından biliniyor olmalıdır. Adımları önceden belirlenmiş bir planı takip etmek, müdahale süresini saatlerden dakikalara indirir.